

SECURITY REVIEW

FOR MYSTIC FINANCE



mystic[★]

INSIDE THIS REPORT

CONTENTS

01	AUDIT SUMMARY	03
02	PROTOCOL OVERVIEW	04
03	SCOPE	05
04	AUDITORS	06
05	METHODOLOGY	07
06	RISK CLASSIFICATION	08
07	FINDINGS SUMMARY	09
08	DETAILED FINDINGS	10
	M-01 Calling unstake() Before Cooldown Expiry Resets Plume's Existing 21-Day Unlock Period for Previously Unstaked Funds	10
	L-01 Queued withdrawals can be frozen when a validator is deactivated without being slashed	12
	L-02 Cooldown is over-delayed by one full batch interval when unstake triggers batch processing	14
	L-03 Explicit validator deposits bypass validator concentration caps	16
	L-04 MyPlumeFeed.getMyPlumePrice() oscillates by $\approx$ netReward/totalSupply across every rewards cycle due to a timing mismatch between numerator accrual and the getMyPlumeRewards() subtraction	18
09	DISCLAIMER	20
10	ABOUT KANN AUDITS	21

01 - OVERVIEW

AUDIT SUMMARY

Mystic Finance engaged Kann Audits to perform a security review of the Mystic Finance smart contracts. From 8 – 10 May, a team of 3 security researchers performed a manual review of the in-scope contracts. All findings identified during the assessment are documented in this report.

TOTAL FINDINGS

5

 ISSUES

CRITICAL	-
HIGH	-
MEDIUM	01
LOW	02
INFORMATIONAL	02

ENGAGEMENT DETAILS

PREPARED FOR	Mystic Finance
PREPARED BY	Kann Audits
DATE REPORTED	11 May 2026
REVIEW PERIOD	8 – 10 May

PROTOCOL OVERVIEW

Mystic Finance is a liquid staking protocol built on Plume Network that allows users to stake PLUME and receive myPLUME, a yield-bearing liquid staking token representing their staked position. Validator rewards are automatically claimed and compounded, while users maintain liquidity through instant redemptions or the standard withdrawal process.

03 - WHAT WE REVIEWED

SCOPE

REPOSITORY	https://github.com/mystic-finance/
AUDITED COMMIT	75fe19a
FINAL COMMIT	75fe19a

#	FILE
01	Liquid-Staking/tree/stake-plume-new
02	src/stPlumeMinter.sol
03	src/Periphery/MyPlumeFeed.sol

04 - THE TEAM ON THIS ENGAGEMENT

AUDITORS

KA

Kann

SECURITY RESEARCHER

SH

Shreyash

SECURITY RESEARCHER

VO

Volodymyr

SECURITY RESEARCHER

05 - HOW WE WORK

METHODOLOGY

An engagement with Kann Audits involves a team of security researchers performing independent reviews of the codebase at the start of the engagement, followed by collaborative review sessions where auditors share findings and explore additional attack vectors to improve overall coverage.

The review included a line-by-line manual inspection of the in-scope codebase, along with analysis of the protocol architecture, access control mechanisms and state transitions. The team also assessed the code against common smart contract security best practices and industry standards.

STEP BY STEP

OUR SECURITY PROCESS

01**Kickoff & Context**

A kickoff call to understand architecture, trust boundaries, threat assumptions and intended behaviour.

02**Scope & Preparation**

Confirm the commit, files in scope, dependencies and the riskiest areas. We open a private channel between your team and our auditors.

03**AI First Scan**

Kann AI, our proprietary model built to find security bugs, scans the codebase before the manual review starts.

04**Expert Security Review**

Line-by-line analysis of exploit paths, invariant breaks, edge cases, accounting and integration risks.

05**Findings & Proofs**

Each issue is confirmed, rated and backed by a proof of concept or a precise reproduction path.

06**Mitigation Review**

We review every fix, confirm it resolves the root cause and flag partial or incorrect mitigations.

COVERAGE

THE REVIEW SPECIFICALLY CONSIDERED

- ✓ Testing against common and uncommon attack vectors
- ✓ Contract logic matching the client's intended behaviour
- ✓ Manual line-by-line review by experienced auditors
- ✓ Architecture and design analysis for secure component interactions and clear trust boundaries
- ✓ Compliance with industry best practices and known smart contract security standards
- ✓ Cross-referencing patterns with industry-standard implementations
- ✓ Access control verification
- ✓ State transitions and logic, to detect inconsistencies, unexpected behaviour or exploitation paths

RISK CLASSIFICATION

Severity combines the **impact** of an issue if exploited with the **likelihood** that the conditions for exploitation are met.

● CRITICAL	Directly exploitable with few or no preconditions, leading to theft or permanent loss of funds or loss of control of the system. Must be fixed before deployment.
● HIGH	Directly exploitable vulnerabilities that can lead to significant material loss or critical impact on the system and require immediate fixing.
● MEDIUM	Moderate loss of funds or impact on multiple users, but only under specific conditions. Exploitable without privileged access, but typically requires certain assumptions or edge cases.
● LOW	Issues with limited impact that do not put funds directly at risk, such as edge cases or deviations from documented behaviour.
● INFORMATIONAL	Non-exploitable findings such as best-practice deviations, cosmetic issues or documentation and compliance notes. They do not need urgent remediation but improve code quality and maintainability.

07 - ALL ISSUES

FINDINGS SUMMARY

● CRITICAL	● HIGH	● MEDIUM	● LOW	● INFO
-	-	01	02	02
TOTAL 05 FIXED 03 ACKNOWLEDGED 02				

ID	TITLE	SEVERITY	STATUS
M-01	Calling unstake() Before Cooldown Expiry Resets Plume's Existing 21-Day Unlock Period for Previously Unstaked Funds	● MEDIUM	● FIXED
L-01	Queued withdrawals can be frozen when a validator is deactivated without being slashed	● LOW	● FIXED
L-02	Cooldown is over-delayed by one full batch interval when unstake triggers batch processing	● LOW	● FIXED
L-03	Explicit validator deposits bypass validator concentration caps	● INFORMATIONAL	● ACKNOWLEDGED
L-04	MyPlumeFeed.getMyPlumePrice() oscillates by $\approx$ netReward/totalSupply across every rewards cycle due to a timing mismatch between numerator accrual and the getMyPlumeRewards() subtraction	● INFORMATIONAL	● ACKNOWLEDGED

DETAILED FINDINGS

M-01

Calling unstake() Before Cooldown Expiry Resets Plume's Existing 21-Day Unlock Period for Previously Unstaked Funds

SEVERITY

● MEDIUM

STATUS

● FIXED

SUMMARY

The protocol batches validator unstakes through `processBatchUnstake()` which internally calls:

```
plumeStaking.unstake(validatorId, amountToUnstake );
```

However, the underlying Plume staking system maintains a single cooldown position per validator. If `unstake()` is called again before the existing 21-day cooldown inside Plume finishes, the cooldown timer for the previously unstaked amount is reset together with the new unstake amount.

This causes already cooling funds to become relocked for another full cooldown duration. Within the current implementation, additional queued withdrawals can trigger another batch unstake while a validator is still inside its active cooldown period:

```
if (
  totalQueuedWithdrawalsPerValidator[validatorId] ≥ withdrawalQueueThreshold ||
  block.timestamp ≥ nextBatchUnstakeTimePerValidator[validatorId]
) {
  _processBatchUnstake(validatorId);
}
```

As a result, newly queued withdrawals are merged into the existing validator cooldown position and restart the entire 21-day timer inside Plume for both old and new funds.

IMPACT

Users whose withdrawals are close to completion may unexpectedly have their cooldown reset back to 21 days due to later withdrawal activity.

RECOMMENDATION

Prevent additional batch unstakes from being executed while a validator already has an active cooldown in progress.

Instead of globally increasing `withdrawalQueueThreshold`, enforce a per-validator restriction during the cooldown window so queued withdrawals cannot retrigger another unstake before the current cooldown matures.

Proposed mitigation:

```
if (block.timestamp < nextBatchUnstakeTimePerValidator[validatorId]) {  
    require(  
        amount + totalQueuedWithdrawalsPerValidator[validatorId]  
        < withdrawalQueueThreshold,  
        "oversubscribed"  
    );  
}
```

■ REMEDIATION

● FIXED

L-01

Queued withdrawals can be frozen when a validator is deactivated without being slashed

SEVERITY

● LOW

STATUS

● FIXED

SUMMARY

Commit `75fe19a` adds an `active` gate to the batch-unstake path in order to avoid calling `plumeStaking.unstake()` for slashed validators. However, the same change also blocks queued withdrawal processing for validators that are merely inactive but not slashed.

This matters because the upstream Plume staking layer distinguishes `inactive` from `slashed`:

- `slashed` validators are blocked for unstake operations
- validators that are only `inactive` are not slashed, and their stake remains recoverable

As a result, if users already have queued withdrawals on a validator and that validator is later deactivated, the queue can stop progressing even though the underlying Plume layer would still permit unstaking.

ROOT CAUSE

The PR uses `getValidatorStats(...).active` as a proxy for “safe to process queued exits”.

That proxy is too strict.

For queued withdrawal liveness, the important condition is whether the validator is **slashed**, not whether it is currently **active**.

RELEVANT CODE

The regression is centered in two places inside `src/stPlumeMinter.sol`. First, `processBatchUnstake()` now skips any validator whose `active` flag is false:

```
function processBatchUnstake() external {
    uint numVals = numValidators();
    uint256 index = 0;
    while (index < numVals) {
        uint16 validatorId = uint16(validators[index].validatorId);
        (bool active,,, ) = plumeStaking.getValidatorStats(validatorId);
        if (active && (totalQueuedWithdrawalsPerValidator[validatorId] ≥
            withdrawalQueueThreshold || block.timestamp ≥
            nextBatchUnstakeTimePerValidator[validatorId])) {
            _processBatchUnstake(validatorId);
        }
        index++;
    }
}
```

Second, `unstakeGov()` uses the same `active` dependency, so governance cannot use it to flush the stuck queue while the validator remains inactive:

```
function unstakeGov(uint16 validatorId, uint256 amount) external nonReentrant
    onlyByOwnGov returns (uint256 amountRestaked) {
        _rebalance();
        (bool active, ,uint256 stakedAmount,) = plumeStaking.getValidatorStats(uint16(
            validatorId));
        uint256 queued = totalQueuedWithdrawalsPerValidator[validatorId];
        uint256 total = amount + queued;
        if (active && stakedAmount > 0 && stakedAmount ≥ total) {
            amountRestaked = plumeStaking.unstake(uint16(validatorId), total);
            totalQueuedWithdrawalsPerValidator[validatorId] = 0;
            nextBatchUnstakeTimePerValidator[validatorId] = block.timestamp +
                batchUnstakeInterval;
        }
    }
}
```

■ ATTACK / FAILURE SCENARIO

1. Users queue standard withdrawals against validator `v`. 2. Before the queued amount is processed, governance deactivates `v` without slashing it. 3. `totalQueuedWithdrawalsPerValidator[V]` remains non-zero. 4. `processBatchUnstake()` skips `v` because `active == false`. 5. `unstakeGov()` also cannot flush the queue because it is gated on the same `active` condition. 6. Pending withdrawals remain stuck until governance re-activates `v`.

■ IMPACT

This is a withdrawal liveness issue.

Affected users can be left waiting indefinitely for governance intervention even though the stake is not slashed and should still be recoverable.

■ REMEDIATION ● FIXED

L-02

Cooldown is over-delayed by one full batch interval when unstake triggers batch processing

SEVERITY

● LOW

STATUS

● FIXED

SUMMARY

When a user unstake request triggers `processBatchUnstake`, the contract updates

```
nextBatchUnstakeTimePerValidator[validatorId] to block.timestamp + batchUnstakeInterval
```

before computing the user's cooldown timestamp. `unstake` then derives `request.timestamp` from this updated "next batch schedule" value instead of the actual unstake initiation time. This introduces an unintended extra delay of `batchUnstakeInterval` to user withdrawals.

ROOT CAUSE

The cooldown timestamp is derived from `nextBatchUnstakeTimePerValidator` after `processBatchUnstake` mutates it for scheduling future batches.

Expected source for user cooldown: actual unstake initiation time (current transaction execution time). Actual source used: next scheduled batch time.

TECHNICAL DETAILS

In `unstake` (single-validator branch):

- Queue is increased.
- If threshold/time condition is met, `processBatchUnstake` is called.
- `processBatchUnstake` sets `nextBatchUnstakeTimePerValidator = block.timestamp`

```
+ batchUnstakeInterval.
```

- `cooldownTimestamp` is set to `plumeStaking.getCooldownInterval() + nextBatchUnstakeTimePerValidator`.

Result: cooldown becomes `now + batchUnstakeInterval + externalCooldown`.

In `unstake` (multi-validator branch):

The same pattern is repeated per validator, and `cooldownTimestamp` takes the maximum end time, where each end time uses the already-forwarded `nextBatchUnstakeTimePerValidator`.

Result: same unintended extra delay across all affected validators.

WHY THIS IS INCORRECT

`nextBatchUnstakeTimePerValidator` is a scheduling variable for future batch execution, not a record of when unstake was actually executed.

Using it as the basis for withdrawal cooldown conflates “next batch slot scheduling” with “actual unstake execution time”.

■ IMPACT

Users whose unstake requests trigger batch execution must wait approximately `batchUnstakeInterval` longer than intended by the underlying staking cooldown.

With defaults (`batchUnstakeInterval = 21 days + 1 hour`), this becomes a material lockup extension that significantly delays withdrawals and degrades protocol UX and trust.

■ POC

Assume `cooldownInterval = C` and `batchUnstakeInterval = B`. At time `T`:

- User submits unstake and triggers `processBatchUnstake`.
- External cooldown should end at `T + C`.
- Contract stores `request.timestamp = C + (T + B) = T + B + C`.
- `withdraw()` enforces `block.timestamp ≥ request.timestamp`.

Result: user is forced to wait an additional `B` time.

■ RECOMMENDATION

Do not derive request cooldown from `nextBatchUnstakeTimePerValidator`.

Instead, derive cooldown from actual batch unstake execution time (e.g. `block.timestamp` at `processBatchUnstake`) or maintain a separate `lastBatchUnstakeTimePerValidator` updated only on execution.

Keep `nextBatchUnstakeTimePerValidator` strictly for scheduling logic.

■ REMEDIATION

● FIXED

L-03

Explicit validator deposits bypass validator concentration caps

SEVERITY

● INFORMATIONAL

STATUS

● ACKNOWLEDGED

SUMMARY

`getNextValidator()` enforces `maxValidatorPercentage` for auto-routed deposits. That check is reached only in the `validatorId == 0` branch of `depositEther()`.

When a user calls `submitForValidator(validatorId)` with an explicit `validatorId`, `depositEther()` enters the explicit-validator branch. That branch only checks:

- validator activity
- validator capacity
- whether the full amount fits the validator's remaining capacity

It does not enforce the governance-configured `maxValidatorPercentage`.

RELEVANT CODE

```
if(_validatorId != 0){
    (uint256 validatorId, uint256 capacity) = _getValidatorInfo(_validatorId);
    (bool active, , , ) = plumeStaking.getValidatorStats(_validatorId);
    require(active, "Validator inactive");
    if(capacity > 0){
        require(_amount <= capacity, "Validator capacity exceeded");
        plumeStaking.stake{value: _amount}(uint16(validatorId));
        ...
    }
    require(remainingAmount == 0, "No capacity");
    return depositedAmount;
}
```

IMPACT

A user can route deposits directly to a validator and bypass the protocol's concentration cap enforcement.

This does not directly cause fund loss, but increases exposure to a single-validator slash beyond the governance-defined risk limits.

PROOF OF CONCEPT

- Validator 1 starts at 90 / 900 total stake.
- Governance caps validator 1 at 10%.
- Attacker calls `submitForValidator { value: 20 ether } (1)`.
- Deposit bypasses cap enforcement in explicit branch.
- Validator 1 exceeds configured concentration limit.

■ **RECOMMENDATION**

Apply the concentration check inside the explicit-validator branch before staking. Ensure the same invariant enforced in auto-routing also applies to direct validator selection:

■ **REMEDIATION**

● **ACKNOWLEDGED**

L-04

MyPlumeFeed.getMyPlumePrice() oscillates by $\approx$ $\frac{\text{netReward}}{\text{totalSupply}}$ across every rewards cycle due to a timing mismatch between numerator accrual and the getMyPlumeRewards() subtraction

SEVERITY

● INFORMATIONAL

STATUS

● ACKNOWLEDGED

SUMMARY

MyPlumeFeed.getMyPlumePrice() is calculated as

```
getTotalDeposits() * 1e18 / frxETH.totalSupply().
```

getTotalDeposits() aggregates protocol-owned PLUME (`info.staked + info.cooled + info.parked + currentWithheldETH`) and subtracts a vested-rewards term:

```
getMyPlumeRewards() = rewardPerToken() * totalSupply() / 1e18
```

When rewards are processed via `loadRewards`, the net reward ($\text{netReward} = 0.9 \cdot \text{reward}$) is transferred back to `stPlumeMinter` and re-staked on the Plume diamond within the same transaction.

This amount is immediately reflected in `info.staked`, or `currentWithheldETH` for amounts below `minStake`.

However, `getMyPlumeRewards()` does not update instantly.

The Synthetix-style `updateReward` modifier in `stPlumeRewards` snapshots `rewardPerTokenStored` and `lastSync` before the new `rewardRate` is applied.

For the remainder of that block:

```
lastTimeRewardApplicable() - lastSync = 0
```

So `rewardPerToken()` returns the pre-load value. As a result, the numerator increases by `netReward` immediately, while the subtractor remains unchanged. This causes `getMyPlumePrice()` to spike by approximately $\frac{\text{netReward}}{\text{totalSupply()}}$. Over the next `rewardsCycleLength` (7 days): `rewardPerToken()` increases linearly, and `getMyPlumeRewards()` gradually catches up by the same `netReward`. The price then decays back to its pre-load value at `rewardsCycleEnd`. This creates a temporary pricing inconsistency across every reward cycle.

ROOT CAUSE

The issue comes from misuse of `getMyPlumeRewards()`.

It is a Synthetix-style reward accumulator. These accumulators are designed to track rolling-vested rewards already registered in the system. They are not intended to be used as balance-sheet accounting entries. At the moment of `loadRewards`, the accumulator lags behind the actual fund inflow by one cycle. `getTotalDeposits()` treats this accumulator as a liability and subtracts it from the numerator. This only aligns correctly when:

```
block.timestamp = rewardsCycleEnd
```

At all other times, numerator and subtractor are out of sync, leading to oscillation in the computed price.

■ **REMEDIATION** ● **ACKNOWLEDGED**

DISCLAIMER

A security audit can never guarantee the complete absence of vulnerabilities. Audits are a time, resource and expertise-bound effort in which we aim to identify as many issues as possible.

This review covers only the files listed in the Scope section at the audited commit. Code changed after that commit, external dependencies, deployment configuration and operational practices may introduce additional risk.

ABOUT KANN AUDITS

Kann Audits is a Web3 security audit company helping DeFi protocols, blockchain networks, and infrastructure teams build securely at every stage, from development to launch and beyond.



EXPERT SECURITY AUDITS

Human-led smart contract security audits built around the architecture, business logic, integrations and risk profile of complex Web3 protocols.



AI SECURITY SCAN

Kann AI extracts Solidity call graphs and returns function-level security signals for expert validation.



FORMAL VERIFICATION

Define security properties for critical protocol behaviour and evaluate whether the implementation satisfies those specifications.



INCIDENT RESPONSE

A direct triage path for suspected exploits, critical vulnerabilities, suspicious transactions and urgent remediation review.



KANN AUDITS
WEB3 SECURITY AUDITS

GET IN TOUCH

WEBSITE	kannaudits.com
PORTFOLIO	github.com/KannAudits
EMAIL	contact@kannaudits.com
X	@KannAudits
TELEGRAM	@KannAudits